Security Incident and Phishing Response Policy

Policy ID: IT-SEC-008 | Version 2.2 | Owner: Security Operations | Effective: 1 June 2026

1. What Counts as a Security Incident

A security incident is any event that may compromise the confidentiality, integrity or availability of Kestrel Analytics systems or data. Examples include a phishing email you interacted with, a malware alert, an unexpected MFA prompt, a lost device, data sent to the wrong recipient, or suspicious activity on your account.

2. Reporting Phishing

Use the Report Phishing button in Outlook to report a suspicious email. It sends the message to Security Operations and removes it from your inbox. Do not forward suspicious emails to colleagues, reply to them, or click their links to check them.

3. If You Clicked a Link or Opened an Attachment

- Disconnect from the network by turning off Wi-Fi or unplugging the cable, but do not shut down the laptop, because evidence in memory is lost on shutdown.
- Call the security hotline on ext. 7100 straight away.
- If you entered your password, change it from another device or ask the Service Desk to reset it.
- Write down what you clicked and when.

4. Severity Levels

- SEV1 (active compromise or a confirmed data breach): Security Operations responds within 15 minutes, 24x7, and the CISO is informed.
- SEV2 (a likely compromise of a single user or device): response within 1 hour.
- SEV3 (suspicious activity with no evidence of compromise): response within 1 business day.

5. Phishing Simulations and Training

Information Security sends simulated phishing emails every month. If you click a link in a simulation, you are assigned a 15-minute training module that must be completed within 7 days. Reporting a simulation with the Report Phishing button counts as a success.

6. After an Incident

A post-incident review is held within 10 business days of every SEV1 and SEV2 incident. Reviews are blameless: they look for causes and fixes, not for people to blame.